



JWT Cafe



Bối cảnh (Context)

Quán cà phê "NextGen Cafe" vừa nâng cấp app đặt hàng của họ lên kiến trúc Microservices và quyết định sử dụng JSON Web Token (JWT) để duy trì phiên đăng nhập thay vì Session truyền thống. Lập trình viên thiết lập JWT bảo rằng: "JWT là công nghệ mã hóa không thể bị phá vỡ vì nó có chữ ký bảo mật".

Nhưng có vẻ họ đã quên đọc kỹ tài liệu hướng dẫn cấu hình của thư viện JWT mà họ đang dùng, đặc biệt là phần liên quan đến thuật toán chữ ký.



Mục tiêu (Objective)

- **Nhiệm vụ:** Giả mạo JWT để biến mình từ một người dùng thường (guest) thành người dùng quản trị (admin).
- **Vấn đề / Lỗi hổng: Insecure JWT Implementation.** Thư viện JWT có thể đã không từ chối thuật toán `None` (kẻ tấn công có thể xóa chữ ký và đổi thuật toán thành `alg: none`), hoặc ứng dụng sử dụng một Khóa bí mật (Secret Key) vô cùng yếu, rất dễ bị dò ra bằng từ điển (Dictionary Attack/Bruteforce).
- **Flag:** Đăng nhập vào trang Admin bằng JWT đã giả mạo.



Gợi ý (Hints)

- Token JWT gồm 3 phần phân cách bởi dấu chấm `.`. Hãy decode phần Header và Payload bằng Base64.
- Đổi phần Payload từ `user` thành `admin`.
- Thử đặt Header thuật toán là `none` và xóa phần chữ ký ở cuối (vẫn giữ nguyên 2 dấu chấm).
- Nếu cách trên không được, hãy thử dùng công cụ `jwt_tool` hoặc `hashcat` để crack mật khẩu của token.